

Software Requirements Specification

CAutomation / CCore / User & Client Management

Document status: Baseline production contract for the User & Client Management reference project. Only this SRS and the matching ATS are manually authored and approved at module level. This baseline hardens the module contract for deterministic planning and generation while enforcing multi-tenant client isolation, user membership boundaries, and role lifecycle states.

1. Purpose, Scope, and Source-of-Truth Rule

This SRS defines what the User & Client Management epic must support from a business and product perspective. It is a functional contract, not an implementation design. It defines the approved multi-tenant hierarchy, functional concepts, administrative workflows, security perimeter rules, validation expectations, and acceptance criteria used by the CAutomation AI Engine.

The SRS answers what must be built and why it is required. The ATS answers how the approved SRS is implemented. The ATS must not introduce business requirements absent from this SRS. If generated artifacts conflict with this SRS, this SRS wins. If behavior must change, this SRS is updated and approved before regeneration.

2. Business Context and Approved Hierarchy

The User & Client Management epic belongs to the following approved CAutomation hierarchy. The labels must appear consistently in generated agile artifacts, UI labels, reports, and traceability output.

Level	Approved value	Business meaning
Project	CAutomation	The top-level software initiative and product family boundary.
Product	CCore	The core CAutomation product that owns shared platform capabilities.
Module	User & Client Management	The multi-tenant administration module that manages users, clients, roles, memberships, and tenant onboarding boundaries.
Epic	User & Client Management	The functional epic for creating client accounts, managing user lifecycles, establishing project memberships, and enforcing strict data isolation.

3. In Scope and Out of Scope

In scope

Maintain Client accounts, User records, Role assignments, Client Memberships, Project Memberships, User Invitations, Validation logs, and Administrative Action Reports.

Maintain metadata lookup states for Client Status, Client Type, User Status, Registration Type, Role Type, Membership Status, and Invitation Status.

Execute secure client onboarding, user provisioning, role configuration, and strict backend tenant data isolation checks.

Generate agile planning artifacts from approved functional scope.

Expose deterministic validation and auditing behavior for security perimeters.

Out of scope

Changing repository folder structure or creating new AI Engine pipeline folders.

Defining or implementing platform-wide network authentication, OAuth providers, or session tokens (inherited from Project Contracts).

Executing arbitrary AI prompts, generating backend source files, running pipeline tasks, or modifying workflow environments.

Inventing user management requirements or mutating project configurations during downstream execution stages.

Replacing project-level contracts; project-level SRS/ATS documents are deferred to a later iteration.

4. Actors and Permissions

Actor	Business responsibility	Required permissions
Platform Owner	Owns platform-wide rules, client registration governance, global metrics, and multi-tenant isolation configuration.	Read all, approve global specification modifications, provision client tenants.
System Administrator	Maintains operational settings, user provisioning channels, lookup values, audit logs, and account activation flags.	Create, read, update, archive, restore, validate administrative assets.
Client Administrator	Manages a specific client account, invites client users, assigns localized roles, and sets project authorization context.	Create users inside tenant boundary, view client reports, update memberships, assign roles.

Actor	Business responsibility	Required permissions
Client Member	Contributes to assigned tasks within explicit project visibility perimeters assigned by their Client Administrator.	Read tenant assets, modify profile details, view assigned project records.
AI Engine	Consumes approved SRS and ATS boundaries to generate deterministic administrative source code without inserting assumptions.	Read approved contract schemas only.

5. Business Domain Model

The domain architecture structurally enforces absolute isolation between distinct client spaces. A User exists as a global identity entity but cannot access data or perform operations without an explicit, active Client Membership or Project Membership mapped directly to a Client tenant account context. Roles are evaluated hierarchically at backend runtime layers to prevent cross-tenant escalation or visibility leaks.

Entity	Business description	Parent or association	Lifecycle expectation
Client	A business customer or distinct tenant account boundary containing projects and users.	None.	Draft, Active, Suspended, Archived.
Client Metadata	Lookup records that classify client industry, market segment, and operational target.	None.	Active or Archived lookup value.
User	An individual account identity registered on the CAutomation platform.	None.	Draft, Active, Suspended, Archived.
Role	Functional authority definition mapping explicit access clearances to identity vectors.	Global Catalog.	Active or Archived lookup value.
Client Membership	Association record pinning a User global identity directly into a Client tenant account context.	Client plus User.	Active, Suspended, Archived.

Entity	Business description	Parent or association	Lifecycle expectation
Project Membership	Association record authorizing a linked user to operate inside an active Project boundary.	Project plus User.	Active, Disabled, Archived.
User Invitation	Cryptographically secure registration ticket issued to provision new tenant resources.	Client plus Issuer.	Pending, Accepted, Expired, Cancelled.
Administrative Report	System-generated audit manifest logging administrative movements and isolation adjustments.	User or Client reference.	Generated, Reviewed, Archived.

6. Functional Requirements

ID	Requirement	Area
SRS-FR-001	The system shall maintain Client records with unique short code, legal name, description, client type, operational status, target classification, and tracking ownership.	Client
SRS-FR-002	The system shall restrict data visibility such that users can only view or interact with Client accounts where an explicit membership exists.	Client
SRS-FR-003	The system shall enforce a global identity registry of Users containing unique email identifiers, active profiles, and tracking metrics.	User
SRS-FR-004	The system shall maintain global lookup tables for client classification, user lifecycle states, invitation validation tracking, and resource roles.	Metadata
SRS-FR-005	The system shall execute tenant user registration only after validating a cryptographic User Invitation reference token.	Onboarding
SRS-FR-006	The system shall maintain a catalog of system-wide Roles independent of individual user identities.	Role
SRS-FR-007	The system shall map a User to a Client space through a distinct Client Membership tracking entity.	Membership

ID	Requirement	Area
SRS-FR-008	The system shall encapsulate Project access scopes through a dedicated Project Membership entity bound by sequence permissions.	Membership
SRS-FR-009	The system shall immediately block access to all downstream module components if a Client or Client Membership state shifts to Suspended or Archived.	Lifecycle
SRS-FR-010	The system shall log every user provisioning, invitation generation, and configuration transition as an unalterable auditing row.	Audit
SRS-FR-011	The system shall generate explicit Administrative Reports tracking user onboarding, permission mutation metrics, and visibility drift indicators.	Reporting
SRS-FR-012	The system shall enforce all multi-tenant ownership boundaries at server application service layer checking active account perimeters.	Isolation
SRS-FR-013	The system shall structure generated authorization components directly from these functional specifications without creating external pathways.	AI Boundary

7. Business Data and Field Rules

Entity scope	Business field	Rule
All identities	id	Required stable identifier. User-visible only where useful for multi-tenant tracing.
All identities	name	Required human-readable label. Must be unique within the specific operational client scope.
All identities	code	Required stable uppercase or snake_case token for multi-tenant generation, isolation checks, and mapping keys.
Client / User	description	Optional tracking remarks detailing account purpose or provisioning notes.

Entity scope	Business field	Rule
Client	type/status/target	Required structural references to active lookup database values checked before system interaction.
Client Membership	client_id + user_id	Required compound primary key isolating an explicit membership assignment within exactly one client space.
User	email	Required globally unique address pattern used as core root locator for platform identification.
User Invitation	token_hash	Required unique cryptographic string token mapped to expiration rules and registration channels.
Memberships	status	Required operational lookup value enforcing access clearance switches.
Administrative Report	report_type	Required classification label detailing isolation audit, registration trace, or membership drift manifests.

8. Relationship and Lifecycle Rules

- A Client account cannot access information belonging to another Client under any context.
- A User global identity cannot possess permissions within a tenant container unless an active Client Membership exists linking them to that container.
- A Project Membership cannot be established unless the target User has a pre-existing, valid Client Membership on the parent Client account.
- A User Invitation cannot map to multiple Client accounts; it must be permanently bound to the single issuing Client tenant workspace upon generation.
- Global roles (Platform Owner, System Administrator) cannot be localized inside client membership matrices; they bypass client bounds via explicit platform checks.
- Deletion of Client records, User accounts, or Membership histories is strictly forbidden; soft-archiving is the mandated ledger mechanism.

- Suspended parent Client accounts instantly freeze all subordinate memberships, user access endpoints, and structural project contexts managed inside that container.

9. User Workflows

Workflow	Required behavior
Onboard Client Tenant	Platform Owner registers new Client account, maps baseline targets, and provisions first Client Administrator account.
Configure Onboarding Metadata	System Administrator configures active lookup profiles specifying client parameters, authorization variables, and onboarding flags.
Dispatch User Invitation	Client Administrator issues a unique User Invitation linked to an active Client container and specific target role authorization.
Finalize User Registration	External invitee registers token, inputs unique email, and establishes system-verified platform global identity account.
Coordinate Tenant Memberships	Client Administrator updates localized Client Membership and Project Membership matrices to delegate workspace parameters.
Audit Compliance Perimeters	Auditor or Reviewer extracts Administrative Reports verifying that membership scopes align with isolation constraints.
Freeze Compromised Account	System Administrator triggers Client suspension rule, blocking background processes and user sessions immediately across all layers.

10. Validation Rules

Rule ID	Rule
SRS-VAL-001	Required fields must be verified present at database boundary before any update or create mutation commits to persistence.
SRS-VAL-002	Client short codes and user email definitions must be evaluated for absolute uniqueness across the global network layout.

Rule ID	Rule
SRS-VAL-003	Any account state alteration must match explicitly mapped structural lifecycle configuration sequences.
SRS-VAL-004	Client activation routines require targeted metadata parameters to resolve to system-verified active lookup states.
SRS-VAL-005	Establishing project-level workspace context requires active matching Client Membership records to avoid data leakages.
SRS-VAL-006	Tenant interaction logic requires at least one active assigned Client Administrator user to prevent isolated deadlocks.
SRS-VAL-007	User Invitation ingestion logic must reject expired timestamp strings or cancelled token values before registration triggers.
SRS-VAL-008	User provisioning workflows must validate token integrity values using targeted backend validation blocks.
SRS-VAL-009	Historical isolation action report components must remain completely immutable after original persist execution triggers.
SRS-VAL-010	Membership records cannot reference missing or archived global identity entries or unverified workspace references.
SRS-VAL-011	Runtime permission checks must execute an absolute containment evaluation verifying that requested project context belongs strictly to the authenticated user's active client boundary. If context mismatch is encountered, the transaction must fail explicitly with isolation breach metrics logged.

11. Acceptance Criteria

ID	Acceptance criterion
SRS-AC-001	Generated administrative tracking systems map Client, User, Role, Invitation, Client Membership, and Project Membership schemas smoothly.
SRS-AC-002	Persistence configurations generate unalterable lookup tables locking status boundaries for multi-tenant accounts.
SRS-AC-003	Database generation isolates User global accounts from operational spaces via clean membership intersection entities.
SRS-AC-004	Backend controller API components intercept context mutations, verifying that parent client variables block cross-tenant lookups.
SRS-AC-005	UI layouts expose cross-client breadcrumbs displaying active client tenant scopes, explicit error fields, and audit paths.
SRS-AC-006	Automated functional test blocks evaluate isolation breaches, invalid invitation registration attempts, and account freezes.
SRS-AC-007	System audit logs explicitly link permission modifications back to the tracking entity, date, and initiating Administrator vector.

12. Deterministic Generation Boundary

Agile sprint components, storyboards, tracking frameworks, and authorization tests must be synthesized exclusively from this foundational SRS contract document. Code synthesis execution tracks must consume these parameters alongside the technical configurations outlined in the matching ATS document.

If schema variables, isolation criteria, or status options appear undocumented or ambiguous, code synthesis engines must stop instantly and output a formal specification gap manifest. Generation logic must not modify folder patterns outside this module context or create unapproved project-level layers.

13. Entity-Level Functional Contract

Entity	Create	Read	Update	Special functional rule
Client	Platform Owner provisions initial profile.	System-wide visibility limited to authorized roles.	Allowed while active lookup parameters pass.	Represents individual isolated business perimeter.

Entity	Create	Read	Update	Special functional rule
User	Registration workflow provisions account.	Profile overview views exposed explicitly to self or admin.	Limited to identity tracking data adjustments.	Enforces unified platform profile index tracking.
Role	Global layout defines base constants.	List and mapping matrices open to administrators.	Restricted to avoid privilege escalation bugs.	Anchors structural authority rules across controllers.
User Invitation	Client Administrator dispatches secure token.	Token validation tracking panels exposed locally.	Prohibited except for explicit cancellation commands.	Controls access pipelines during account setup.
Client Membership	Triggered by active invite ingestion loop.	Filtered checks verify local assignment state.	Status values switch between active and suspended vectors.	Connects global platform users to explicit tenants.
Project Membership	Allocated within localized workspace panels.	Listed cleanly inside assigned project boundaries.	Sequence values allow active toggle options.	Confines working parameters to selected project scopes.
Administrative Report	System pipeline saves context logs.	Ledger list available to review authorities.	Forbidden; fields remain immutable after save.	Records tracking logs for multi-tenant state steps.

14. Lifecycle Transition Contract

Record type	Allowed normal transitions	Blocked transitions
Client / User	Draft to Active, Active to Suspended, Suspended to Active,	Archived directly to Active bypassing validation loops;

Record type	Allowed normal transitions	Blocked transitions
	Active/Suspended to Archived, Archived to Suspended when restored.	Active to Draft if downstream project relations are attached.
Role	Draft to Active, Active to Archived, Archived to Draft when restored.	Active to Draft after mapping links are deployed to live client memberships.
User Invitation	Pending to Accepted, Pending to Expired, Pending to Cancelled.	Expired back to Pending; Accepted to Cancelled after registration logic completes.
Client Membership	Active to Suspended, Suspended to Active, Active/Suspended to Archived.	Reverting Archived entries back to active tracking status without executing parent validation loops.
Project Membership	Active to Disabled, Disabled to Active, Active/Disabled to Archived.	Overriding isolation boundaries; mapping users lacking matching client memberships.
Administrative Report	Generated to Reviewed, Generated/Reviewed to Archived.	Archived directly back to Reviewed omitting tracking signatures.

Asynchronous Administrative Processing Mandate: The backend application layers must coordinate long-running background administrative loops—such as global multi-tenant state cascades, batch invitation expirations, or multi-project membership state changes—utilizing native FastAPI BackgroundTasks exclusively. The runtime orchestration code shall utilize this framework to switch states cleanly across tables, executing transitions safely through the structural loop paths. Incorporating external messaging frameworks or third-party task brokers inside this contract layer remains explicitly prohibited.

15. Agile Artifact Generation Contract

Generated artifact	SRS source material	Required deterministic output
Epic	Business context matrix and administrative boundaries.	One epic named User & Client Management under CAutomation / CCore.

Generated artifact	SRS source material	Required deterministic output
Features	Functional requirements list and isolation domain layout.	Feature groups managing client onboarding, user profiles, invitation verification, role assignment, and audit reporting.
User stories	Actor permission matrices and administrative workflows.	Unified stories detailing explicit role goals, security intent, acceptance identifiers, and source tracing keys.
Implementation tasks	Functional sections paired with field matrix boundaries.	Prescriptive developer tickets covering relational schemas, isolation endpoints, validation code, and screen widgets.
Acceptance tests	Verification criteria rules and validation tables.	Explicit positive scenarios and expected breach blocks utilizing stable validation system tags.
Specification gaps	Gaps or missing metadata options.	Isolated exception rows outputting precise technical clarity flags instead of unverified source modifications.

16. Business Scenarios

Scenario	Given	When	Then
Onboard New Client Tenant	Clean platform instance with active lookup metadata profiles deployed.	Platform Owner registers an active Client tenant record with unique code tracking identifiers.	Structural client container is established, parent workspace contexts pass validation, and metrics record cleanly.
Issue Invite and Provision User	Active Client workspace exists with verified configuration boundaries.	Client Administrator issues unique onboarding ticket referencing specific role variables.	Cryptographic token persists safely, mapping resource endpoints to intended invitation rules.
Intercept Cross-Tenant Leakage	Two separate active Client spaces are deployed containing	Authenticated user from Tenant A attempts code mutation queries	Server service checks drop request immediately, firing

Scenario	Given	When	Then
	isolated project lines.	hitting endpoints in Tenant B.	validation block exception SRS-VAL-011.
Trigger Emergency Tenant Suspension	Live client environment operating with multiple active user sessions.	System Administrator alters Client operational status to Suspended within control dashboard.	State changes propagate through tables, instantly blocking downstream session lookups at application layer.
Extract Compliance Audit Report	Multi-tenant platform managing ongoing user onboarding history.	Auditor opens tracking views matching specific timeline parameters.	System aggregates logs cleanly into unalterable report views displaying clear provenance links.

17. Generation Readiness Pass

This section enforces the final completeness validation protocol required before the AI Engine converts this functional contract into backend assets. If any checkpoint fails, the generation process must halt immediately.

Readiness area	Required SRS decision	Generation behavior if missing
Multi-Tenant Hierarchy	Unified mappings defining global platform rules, Client tenant containers, and User memberships must register cleanly.	Abort generation and declare missing multi-tenant hierarchy error.
Tenant Isolation Boundary	Application service logic must forbid cross-tenant operations via explicit validation parameters.	Block API generation and flag missing isolation compliance rules.
User Allocation Patterns	Global user definitions must remain structurally isolated from tenants, connecting only via intersection records.	Terminate schema generation if users collapse directly into singular clients.
Account Lifecycle Sequence	Absolute status parameters and permitted transitions must populate for clients, entries, invites, and profiles.	Output explicit lifecycle gap manifest omitting code invention paths.

Readiness area	Required SRS decision	Generation behavior if missing
Precision Validation Identifiers	Validation blocks must output stable identifier strings matching architectural specifications.	Generate validation perimeter report detailing missing rule parameters.
Audit Compliance Traceability	Every generated model field, schema component, or route must trace back to a valid functional requirement row.	Reject unmapped workspace files during compiler analysis pipelines.

18. Approved Functional Status Values

The following functional status sets are structurally approved for database schema and service application layer integration. Generated code structures must enforce these absolute semantic string choices without variance.

Record type	Approved statuses	Business note
Client	Draft, Active, Suspended, Archived	Suspended status immediately freezes access loops for all assigned members.
User	Draft, Active, Suspended, Archived	Global account tracking state evaluated during base connection verification sequences.
Role	Active, Archived	Global configuration definitions mapping structural operational access scopes.
User Invitation	Pending, Accepted, Expired, Cancelled	Accepted state indicates token has completed registration workflow successfully.
Client Membership	Active, Suspended, Archived	Restricts interface loops within explicit client container spaces.
Project Membership	Active, Disabled, Archived	Controls lower-level clearance paths matching specific workspace items.
Administrative Report	Generated, Reviewed, Archived	Records must preserve historical mapping indicators unchanged to maintain clear traceability.

19. Specification Gap Handling

A specification gap represents a blocking architectural exception where missing operational data requires contract clarification. Generative components must capture anomalies inside formal error manifests rather than synthesizing assumptions.

Gap type	Example	Required output
Business Logic Gap	Functional workflows detail an administrative sequence lacking a verified acceptance path.	Structural exception row mapping the section, missing criteria, severity ranking, and resolution guidance.
Structural Field Gap	An identity or tracking entity is defined inside the prose but lacks matching field matrix rows.	Detailed manifest tracking the layout anomaly and missing variable rules.
State Sequence Gap	An operational tracking status is deployed within a matrix but lacks permitted transition steps.	Isolation error entry detailing target entity type and unmapped state transitions.
Verification Trace Gap	Generated controller routes, schema changes, or UI fields fail to connect to a valid requirement identifier.	Reject compilation stack immediately, reporting complete traceability mapping breakdown.
Code Integration Gap	A business requirement lacks an explicitly defined validation rule inside the ATS layout.	Lock generation loops entirely until technical configurations map to the functional requirement.

20. Minimum Generation Scope

A code generation execution run for this module is evaluated as complete only when it delivers fully functional agile tracking issues, relational database schemas, multi-tenant API filters, backend orchestration code, secure screen interfaces, unit tests, and audit trail viewers matching this complete User & Client Management operational perimeter.

All project-level specifications and global authentication layers remain deferred, and code generation processes must operate within this explicit module scope limit. No files outside this specific module domain configuration may be altered during generation loops.